NPTEL ETHICAL HACKING & NETWORK COMMUNICATIONS

WEEK 8 DETAILED CLASSROOM STUDY NOTES & EXAM PREPARATION NOTEBOOK

Course: NPTEL Ethical Hacking | Coverage: Lectures 36 to 40 (Steganography, Biometrics, DoS/DDoS, Web Security, DNS & PGP Email Security)

MODULE 1: LECTURE 36 — STEGANOGRAPHY & INFORMATION HIDING

1.1 Principles of Steganography: Invisibility vs. Encryption

Simple Explanation: Imagine you want to send a secret letter to a friend. If you put it in a safe locked with a heavy padlock (**Cryptography**), anyone who sees the safe knows you are hiding something valuable. Even if they cannot open the safe, the presence of the lock raises immediate suspicion. However, if you write the secret message in invisible ink between the lines of an ordinary postcard (**Steganography**), an observer reads the postcard and suspects nothing. Steganography is the art and science of hiding the *very existence* of a communication.

Why it is Important: In high-security environments, intelligence operations, or oppressive regimes, sending an encrypted message is illegal or draws lethal attention. By embedding secret messages inside innocent-looking cover media (like digital photos, audio files, or network headers), communication occurs in plain sight without triggering security alarms.

Technical Definition: *Steganography* (derived from Greek *steganos* meaning 'covered' and *graphie* meaning 'writing') is a security mechanism that embeds secret payload data into a non-secret cover medium, producing a stego-medium that is visually and statistically indistinguishable from the original cover.

Security Paradigm	Primary Goal / Objective	Adversary Perception	Key Vulnerability
Steganography	Conceal the *existence* of the message.	Sees ordinary innocent cover media; suspects nothing.	Image manipulation, lossy compression (JPEG).
Cryptography	Conceal the *meaning / readability* of message.	Sees unreadable ciphertext; knows data is hidden.	Key compromise or mathematical cryptanalysis.
Digital Watermarking	Protect copyright and verify origin/ownership.	Watermark may be visible/known; proves legal owner.	Tampering or removal attacks.

1.2 Core Terminology & Steganographic Pipeline

• **Cover Medium:** The original, innocent carrier file (e.g., JPEG image, WAV audio, MP4 video, executable header, network IP packet) used to conceal data.
• **Embedded Message (Payload):** The secret text, image, or binary data being hidden.
• **Stego-Key:** An optional secret key used to encrypt the payload before embedding, ensuring that even if steg-analysis extracts the hidden bits, they remain unreadable.
• **Stego-Medium:** The final output file containing the embedded secret payload.
• **Steg-analysis:** The counter-measure science of detecting hidden messages within digital media.

1.3 Digital Image Architecture & Compression Trade-Offs

To perform image steganography, a student must understand how digital images store color:
1. **Pixels & Resolution:** A digital image is a 2D matrix of picture elements (pixels). An image of 1024×1024 resolution contains $1,048,576$ individual pixels.
2. **24-bit True Color (RGB):** Each pixel's color is defined by 3 color channels: Red, Green, and Blue. Each channel uses 8 bits (1 byte), giving $2^8 = 256$ intensity levels (0 to 255). A single pixel requires 3 bytes (24 bits), allowing for $256^3 \approx 16.7\text{ million colors}$.
- Black: `(0, 0, 0)` | White: `(255, 255, 255)` | Pure Red: `(255, 0, 0)` | Yellow: `(255, 255, 0)`
3. **Image Compression Formats:**
- **GIF (Graphics Interchange Format):** Uses an 8-bit palette (256-color map table) and **Lossless Compression**. Excellent for LSB steganography because exact pixel color indices are preserved perfectly.
- **BMP (Bitmap):** Uncompressed or losslessly compressed 24-bit images. Perfect for LSB steganography.
- **JPEG (Joint Photographic Experts Group):** Uses **Lossy Compression** based on Discrete Cosine Transform (DCT).
Warning: Simple LSB steganography fails on JPEG because lossy compression discards subtle pixel bit modifications, destroying the hidden message!

1.4 Least Significant Bit (LSB) Insertion Mechanics

Working Principle: In an 8-bit binary number (e.g., `11010010`), the leftmost bit is the Most Significant Bit (MSB) and holds a value of 128. Changing the MSB drastically alters the color. The rightmost bit is the **Least Significant Bit (LSB)** and holds a value of 1. Changing the LSB changes the color intensity by only ± 1 out of 255 (a 0.39% change), which is mathematically imperceptible to the human eye!

LECTURE STEP-BY-STEP EXAMPLE: HIDING 'C' IN GIF

Goal: Embed the letter **'C'** into the LSBs of 8 consecutive pixels in an 8-bit GIF image.
• ASCII code for 'C' = 67 in decimal = **01000011** in binary.
• Original 8 pixel bytes from cover image:
1. `10110100` (LSB = 0) | 2. `01101101` (LSB = 1) | 3. `11010010` (LSB = 0) | 4. `00111011` (LSB = 1)
5. `10001100` (LSB = 0) | 6. `01010101` (LSB = 1) | 7. `11100010` (LSB = 0) | 8. `00011101` (LSB = 1)
• Secret bits to embed: **0 1 0 0 0 0 1 1**
• Modified Stego-Bytes (showing LSB changes):
1. `1011010`**0** (No change) | 2. `0110110`**1** (No change) | 3. `1101001`**0** (No change)
4. `0011101`**0** (**Changed 1 -> 0!**) | 5. `1000110`**0** (No change) | 6. `0101010`**0** (**Changed 1 -> 0!**)
7. `1110001`**1** (**Changed 0 -> 1!**) | 8. `0001110`**1** (No change)
Result: The secret letter 'C' is fully embedded! The visual difference in the image is zero.

CORE FORMULA & MATHEMATICAL ANALYSIS

Formula: `Capacity (Bytes) = (Width x Height x b) / 8`

Symbol Explanation:
• **Width (W):** Image horizontal resolution in pixels.
• **Height (H):** Image vertical resolution in pixels.
• **b:** Number of hidden bits per pixel (e.g., $b=1$ for 1 LSB bit per pixel, $b=3$ for 1 bit per RGB channel).

Worked Calculation Step-by-Step:
Problem (NPTEL Assignment 8, Q10): Consider a grayscale image of size 1500×1200, where each pixel is stored using 8 bits. Using LSB steganography (1 bit hidden per pixel), how many bytes of secret information can be hidden?
Step 1: Calculate Total Pixels = $1500 \times 1200 = 1,800,000\text{ pixels}$.
Step 2: Calculate Hidden Bits = $1,800,000\text{ pixels} \times 1\text{ bit/pixel} = 1,800,000\text{ bits}$.
Step 3: Convert Bits to Bytes = $1,800,000 / 8 = \mathbf{225,000\text{ bytes}}$ (or 225 KB).
Final Answer: Exactly **225,000 bytes** can be hidden in the image.

1.6 Advanced Transform Domain Steganography & Lecture Case Studies

To overcome LSB's weakness against image processing, advanced techniques embed data in the mathematical frequency domain:
• **Masking and Filtering:** Selectively modifies busy or textured regions of an image (e.g., grass, foliage) which naturally tolerate visual noise, while leaving smooth areas untouched.
• **Discrete Cosine Transform (DCT):** Used in JPEG images. Payload data is embedded into the frequency coefficients of the DCT block rather than raw pixel values, surviving lossy compression.
• **Discrete Wavelet Transform (DWT):** Decomposes images into frequency sub-bands, providing extreme robustness against cropping, scaling, and filtering.
• **Historical Lecture Case Studies:**
- *Ancient Greece:* Shaving a messenger's scalp, tattooing the secret message, waiting for hair growth, and shaving again at destination.
- *World War II:* German spies extracting the 2nd letter of each word in innocent letters to form intelligence sentences.
- *Modern Visual Artifacts:* Hiding a military satellite base map inside a classical artwork painting, and embedding a complete face image inside a baboon's face image.

EXAM POINT / COMMON MISTAKE

NPTEL Exam Focus: Remember that LSB steganography requires **Lossless** compression (GIF, BMP). JPEG uses **Lossy** compression (DCT) which destroys simple LSB data. Also memorize the capacity formula $W \times H \times b / 8$ for image questions!

MODULE 2: LECTURE 37 — BIOMETRIC AUTHENTICATION SYSTEMS

2.1 Foundational Principles & Physical Presence Requirement

Simple Explanation: Passwords can be forgotten, written on sticky notes, or stolen by keyloggers. Smart ID cards can be lost or borrowed by a colleague. In security terms, passwords are *something you know* and cards are *something you have*. **Biometrics** represent *something you are*. A person cannot leave their retina or fingerprint at home!

Why it is Needed: Traditional authentication proves that a valid password was entered, but cannot guarantee *who* typed it. Biometric authentication requires the physical presence of the individual at the verification point, creating an unbreakable link between a digital transaction and a real human body.

Technical Definition: *Biometric Authentication* is an automated system that recognizes individuals by acquiring, processing, and pattern-matching their unique biological (physiological) or behavioral characteristics against pre-enrolled vector templates.

2.2 Comprehensive Taxonomy: Biological vs. Behavioral Traits

Biometric characteristics fall into two broad categories:
1. **Biological (Physiological) Characteristics:** Inherent physical body structures that remain highly stable over a person's lifetime.
2. **Behavioral Characteristics:** Learned patterns of physical activity and movement that reflect individual habits.

Biometric Modality	Category	Key Feature / Extract Mechanism	Limitations & Vulnerabilities
Fingerprint	Biological	Extracts **Minutiae** points (ridge endings, bifurcations, deltas, cores, islands).	Affected by dirt, cuts, dry skin; lower reliability in heavy manual labor.
Hand Geometry	Biological	Measures finger length, thickness, hand width, and 3D shape contours.	Requires large hardware scanner footprint; less unique than iris.
Iris Scan	Biological	Analyzes intricate random patterns in the iris using infrared light camera.	High uniqueness; non-intrusive; moderately expensive hardware.
Retina Scan	Biological	Scans blood vessel patterns at the back of eye (retinal wall).	**Highest Uniqueness** (unique in twins & left/right eyes); user must stare closely into laser.
Facial Recognition	Biological	Measures distances between landmark features (eyes, nose, chin, ears).	Sensitive to lighting, facial expressions, aging, and angles.
Signature Dynamics	Behavioral	Measures stroke speed, pen pressure, pen angle, and acceleration.	Can vary with fatigue, emotional state, or physical injury.
Keystroke Dynamics	Behavioral	Measures typing speed, key dwell time, and flight time between keys.	Requires continuous background monitoring; varies with keyboards.
Gait Analysis	Behavioral	Analyzes unique walking style, stride rhythm, and body posture.	Affected by footwear, carrying loads, or joint injuries.
DNA Matching	Biological	Analyzes unique genetic code profiles.	**Unsuitable for real-time auth** due to slow laboratory processing time.

2.3 Minutiae Vector Extraction in Fingerprints

Crucial Concept: Biometric systems *do NOT store raw images* of fingerprints or faces in their databases! Storing raw images would consume massive storage and create catastrophic privacy risks if hacked.
Instead, during enrollment, the system extracts specific coordinate landmarks known as **Minutiae**:
• *Ridge Ending:* The point where a fingerprint line stops abruptly.
• *Bifurcation:* The point where a single ridge splits into two branches.
• *Core & Delta:* Center loops and triangular ridge intersections.
These (x, y, θ) minutiae coordinates are compressed into a small mathematical **Biometric Template** (often < 1 KB). During verification, the live scan template is mathematically matched against the stored template.

2.4 Operational Modes: 1-to-1 Verification vs. 1-to-N Identification

A biometric system functions in one of two distinct operational modes:

1. **One-to-One (1:1) Verification (Authentication):**
- *User Claim:* The user explicitly claims an identity (e.g., enters Username 'Alice' or swipes a smartcard).
- *Process:* System fetches **only Alice's stored template** and compares it against the live scan.
- *Question Answered:* **'Are you who you claim to be?'**
- *Applications:* Unlocking smartphones, logging into laptop accounts, ATM cash withdrawals.

2. **One-to-N (1:N) Identification (Database Search):**
- *User Claim:* The user claims NO identity; presents only their biometric sample.
- *Process:* System compares the live sample against **all N templates** in a massive central database.
- *Question Answered:* **'Who are you?' (or 'Are you in our database?')**
- *Applications:* Criminal AFIS investigation, border passport control, national ID systems (Aadhaar UID).

2.5 Multimodal Biometrics & Partial Matching Thresholds

• **Multimodal Biometrics:** Combining two or more distinct traits (e.g., Iris + Fingerprint, or Face + Voice) dramatically increases accuracy, prevents spoofing (e.g., holding up a printed photo), and compensates for individual trait failures.
• **Partial Matching & Thresholds:** Unlike passwords where entry must be 100% exact, live biometric samples vary due to angle, pressure, or lighting. Systems perform probabilistic matching and calculate a similarity score. If the score exceeds a calibrated **Acceptance Threshold**, access is granted.

EXAM POINT / COMMON MISTAKE

NPTEL Exam Practice Focus: Remember that **Signature, Gait, and Keystroke dynamics** are *Behavioral* biometrics, while **Retina, Iris, Fingerprint, and Hand Geometry** are *Biological* biometrics. DNA is biological but cannot be used for instant authentication!

MODULE 3: LECTURE 38 — NETWORK-BASED ATTACKS (PART I): DENIAL OF SERVICE

3.1 Principles of Denial of Service (DoS) Attacks

Simple Explanation: Imagine a busy bank branch with 5 teller windows. A malicious person hires 100 fake actors to stand in line all day, constantly asking time-consuming questions but never making transactions. Real customers standing outside cannot enter the bank and are denied service. In computer networks, a **Denial of Service (DoS)** attack overwhelms a server or network link so legitimate users cannot access it.

Why it is Important: DoS attacks target the *Availability* pillar of the CIA triad. Unlike data theft, a DoS attack does not require cracking passwords or stealing database records; it simply weaponizes standard network protocol features to crash or saturate a target.

Technical Definition: A *Denial of Service (DoS)* attack is an explicit attempt by an attacker to render a target system, application, or network service unavailable to legitimate users by exhausting its computational resources (CPU, RAM, connection buffers) or network bandwidth.

3.2 The Smurf DoS Attack (ICMP Broadcast Amplification)

Working Principle: The Smurf attack exploits the ICMP Echo Request/Reply (ping) mechanism combined with IP spoofing and network broadcast addresses to achieve massive traffic amplification.
Step-by-Step Attack Mechanics:
1. *Constructing Spoofed Ping:* The attacker crafts an ICMP Echo Request packet. The source IP address is spoofed to be the **Victim's IP Address**.
2. *Targeting Broadcast Address:* The destination IP address is set to an intermediate network's **Broadcast Address** (e.g., `192.168.1.255`).
3. *Amplification:* The intermediate network router receives the broadcast ping and forwards it to every host on that network segment (e.g., 10,000 computers).
4. *Flooding the Victim:* All 10,000 computers simultaneously generate ICMP Echo Replies and send them to the source IP (the Victim!).
5. *Denial of Service:* The victim's network interface and buffers are overwhelmed by tens of thousands of unsolicited ping replies, crashing the connection.
Mitigation: Configure edge routers on all networks to drop incoming external packets addressed to IP broadcast destinations (`no ip directed-broadcast`).

3.3 The Ping of Death Attack (Oversized Packet Crash)

Working Principle: The maximum allowed size of an IPv4 packet (including header and payload) is $65,535\text{ bytes}$ (64 KB). The Ping of Death deliberately crafts an ICMP Echo packet larger than 65,535 bytes.
Step-by-Step Attack Mechanics:
1. *Packet Crafting:* Attacker generates an ICMP payload exceeding $65,536\text{ bytes}$.
- *CLI Command Example:* **`ping -f -s 65537 [Target_IP]`** (where `-s 65537` specifies payload $>65,536$, and `-f` floods packets as fast as possible).
2. *Fragmentation:* The attacker's IP stack splits the oversized packet into multiple smaller IP fragments to pass over Ethernet MTU links.
3. *Reassembly Crash:* The target OS receives and reassembles the fragments. When the total reassembled size exceeds the 65,535-byte memory allocation buffer, an integer overflow / buffer overflow is triggered, causing the target operating system to freeze, crash, or reboot!
Mitigation: Operating system patches that validate reassembled IP packet lengths before allocating memory buffers.

3.4 TCP SYN Flooding Attack & SYN Cookie Defense

Working Principle: SYN Flooding exploits the standard 3-Way Handshake protocol used to establish TCP connections (`SYN` -> `SYN-ACK` -> `ACK`).
Step-by-Step Attack Mechanics:
1. Attacker sends a rapid flood of TCP `SYN` connection request packets to the target server's open port (e.g., Port 80).
2. The source IP in every `SYN` packet is **spoofed** to non-existent or unreachable IP addresses.
3. Upon receiving each `SYN`, the server allocates Transmission Control Block (TCB) memory, enters the `SYN_RCVD` state, and sends a `SYN-ACK` to the spoofed IP.
4. Since the spoofed IP address does not exist, no final `ACK` is ever returned to the server.
5. The server holds these **Half-Open Connections** in its backlog queue waiting for a timeout.
6. The connection table fills completely with half-open requests. When legitimate users attempt to connect, the server drops their requests!
Asymmetry of Cost: Attacker spends minimal CPU/RAM sending tiny raw `SYN` packets, while Server spends heavy memory allocating TCB state for thousands of bogus connections.

DEFENSE MECHANISM: SYN COOKIES

MITIGATION: SYN COOKIES MECHANISM
To protect servers from SYN Flooding, OS kernels implement **SYN Cookies**:
1. When a `SYN` packet arrives, the server *does NOT allocate any TCB memory state*!
2. Instead, the server computes a 32-bit cryptographic hash (Cookie) derived from the client IP, port, server secret key, and timestamp.
3. The server embeds this Cookie as the Initial Sequence Number (ISN) in its `SYN-ACK` response.
4. If the client is legitimate, it responds with an `ACK` containing sequence number `Cookie + 1`.
5. The server re-computes the cookie hash. If it matches, the server confirms a real client and *only then allocates connection memory*!
Result: Bogus spoofed `SYN` packets consume zero server memory!

EXAM POINT / COMMON MISTAKE

NPTEL Exam Focus: Memorize the 3 DoS attacks:
• **Smurf:** ICMP Echo + Broadcast Address + IP Spoofing (Mitigated by blocking directed broadcasts).
• **Ping of Death:** Oversized ICMP > 65,535 bytes causing reassembly crash.
• **SYN Flood:** Exploits TCP 3-way handshake creating half-open connections (Mitigated by SYN Cookies).

MODULE 4: LECTURE 39 — NETWORK-BASED ATTACKS (PART II): DDOS & WEB SECURITY

4.1 Distributed Denial of Service (DDoS) Architecture

Simple Explanation: If a single person throws pebbles at your window, you can easily close the shutter or call the police on that individual. But if a crowd of 10,000 people standing all across the city throws pebbles at the same time, you cannot block them individually. A **Distributed Denial of Service (DDoS)** attack scales DoS by utilizing thousands of infected machines to attack a target simultaneously.

Why it is Important: Modern enterprise firewalls easily block a single IP sending too many packets (Rate-Limiting). But in a DDoS attack, each of the 50,000 infected machines sends only a small, normal-looking amount of traffic, making it extremely difficult to distinguish attack packets from real user requests.

Architectural Components of a DDoS Attack:
1. **Attacker:** The human adversary who coordinates and commands the attack campaign.
2. **Handlers (Masters):** Intermediate compromised servers controlled by the attacker. Handlers act as a Command-and-Control (C2) layer, taking instructions from the attacker and issuing commands to thousands of bots.
3. **Bots (Zombies):** Compromised end-user devices (PCs, servers, routers, IoT devices) infected with malware that execute repetitive attack scripts.
4. **Botnet:** The massive network pool of thousands or millions of bots controlled collectively by handlers.

DDoS Component	Role in Attack Pipeline	Security Significance
Attacker	Issues high-level target commands.	Detaches from the network after issuing command to remain anonymous.
Handlers (Masters)	Relays commands to sub-networks of bots.	Provides abstraction; masks the real attacker's IP address.
Bots (Zombies)	Generates raw packet floods to victim.	Infected without owner knowledge; often spoofs source IP addresses.

Botnet	Collective pool of infected hosts.	Generates massive distributed bandwidth (e.g., Hundreds of Gbps).

4.2 Application-Layer (Layer 7) HTTP Flood Attacks

HTTP Flood attacks target web servers directly at Layer 7 by overwhelming them with HTTP requests:
• **HTTP GET Flood:** Bots send thousands of concurrent HTTP GET requests asking for large web pages, images, or PDF downloads. The web server exhausts CPU and disk I/O attempting to fetch files from disk.
• **HTTP POST Flood (Asymmetry Exploitation):**
- *Resource Asymmetry:* A client POST request requires minimal client bandwidth (< 200 bytes) to send form data (e.g., search parameters or login credentials).
- *Server Overhead:* Upon receiving a POST request, the web server must execute backend application logic (Java, PHP, Python), establish database connections, execute complex SQL queries, and generate dynamic HTML.
- *Attack Impact:* Sending a high volume of POST requests rapidly crashes the database connection pool and backend application server, shutting down the website!

4.3 Technical Challenges in Locating DDoS Attackers

Attributing a DDoS attack to the real human attacker is notoriously difficult due to 5 factors:
1. *Attacker Detachment:* The attacker sends a command to handlers and immediately logs off, leaving handlers and bots running autonomously.
2. *Multi-Tier Abstraction:* Handlers act as proxy shields between the attacker and bots.
3. *IP Spoofing:* Bots forge packet headers to make traffic appear as if it comes from random third-party IPs.
4. *Geographic Dispersion:* Bots are scattered across hundreds of global ISPs and jurisdictions.
5. *Log Coordination Constraints:* Tracing requires synchronized router logs across non-cooperative international ISPs.

4.4 Multi-Layered Defense & Safeguard Mechanisms

Effective defense against DDoS requires a coordinated multi-tier strategy:
1. **ISP-Level Protections:**
- *Anti-Spoofing Ingress Filters (RFC 2827 / BCP 38):* Routers check if an incoming packet's source IP belongs to the expected subnet. If forged, the router drops it.
- *Disable IP Broadcasts:* Disabling directed broadcast processing on routers neutralizes Smurf-style amplification.
2. **Victim Network Protections:**
- *Border Inspection & Queue Monitoring:* Monitoring router queue overflows and packet drop rates.
- *Close Unused UDP Services:* Closing non-essential UDP ports (which lack connection handshakes and are easy to spoof).
3. **Web Application Protections (HTTP Flood Mitigation):**
- *CAPTCHA Challenges:* Requires human visual/cognitive interaction that automated bots cannot solve.
- *JavaScript Math Challenges:* Serves a small computational puzzle to the client browser before rendering pages.
- *Web Application Firewalls (WAF):* Inspects HTTP headers, evaluates IP reputation databases, and blocks suspicious POST/GET request patterns.

EXAM POINT / COMMON MISTAKE

Exam Focus: Understand why **HTTP POST floods** are more destructive than GET floods: POST requests trigger complex backend program execution and database SQL queries, creating a severe **Resource Asymmetry** between client and server!

MODULE 5: LECTURE 40 — DNS & EMAIL SECURITY (DNSSEC & PGP)

5.1 Domain Name System (DNS) Fundamentals & Resolution

Simple Explanation: When you call a friend, you select their name in your phone contacts rather than memorizing their 10-digit phone number. The **Domain Name System (DNS)** is the phonebook of the internet. It translates human-readable domain names (e.g., `www.nptel.ac.in`) into numerical IP addresses (e.g., `14.139.60.100`) that routers use to deliver data.

Why it is Important: If an attacker tampers with DNS, typing your bank's web address into your browser will silently load a malicious phishing site, leading to immediate credential theft. DNS security is the linchpin of internet trust.

DNS Name Resolution Methods:
• **Iterative Name Resolution:** The client queries the local DNS server. If missing, the local server returns a referral (suggested higher-level server IP). The client directly manages the step-by-step queries to Root, TLD, and Authoritative DNS servers.
• **Recursive Name Resolution:** The client sends a single request to the Local DNS Server. The local server takes on full responsibility, querying higher-level servers on behalf of the client, and returns the final IP address.

5.2 DNS Caching & The DNS Cache Poisoning Attack

DNS Caching Mechanics: To avoid querying global servers for every request, local DNS resolvers store resolved IP mappings in local RAM cache for a duration specified by the record's *Time To Live (TTL)*.
Inherent Protocol Vulnerabilities: Standard DNS transmits in plaintext, lacks origin authentication, and relies on **connectionless UDP** (making source IP spoofing easy).
Step-by-Step DNS Cache Poisoning Attack:
1. Attacker sends a DNS query to a Target Local Resolver for domain `sbi.in`.
2. Target Resolver, lacking the record, forwards a query to the Authoritative DNS server.
3. Immediately, the Attacker floods the Target Resolver with hundreds of fake DNS responses containing a **Malicious IP Address** (`192.168.1.66`).
4. The attacker spoofs the source IP of the fake responses to match the Authoritative DNS server.
5. If a fake response arrives before the real response, the Target Resolver accepts it and stores the malicious IP in its local cache!
6. All network clients asking the Target Resolver for `sbi.in` are redirected to the attacker's phishing website!

5.3 DNS Security Extensions (DNSSEC)

DNSSEC Overview: DNSSEC adds cryptographic security to DNS to neutralize cache poisoning.
Three Core Protections:
1. *Origin Authentication:* Cryptographically verifies that a response originates from the true authoritative DNS server.
2. *Data Integrity:* Guarantees that DNS record data was not modified in transit.
3. *Authenticated Denial of Existence:* Cryptographically proves if a domain record does not exist.
Mechanics: DNSSEC signs DNS resource records with a zone's private key (`RRSIG` records). Resolvers verify signatures using public keys (`DNSKEY`) linked through a cryptographic Chain of Trust.
Drawbacks: Increased server CPU load for signature verification and larger UDP packet sizes.

5.4 Email Security with Pretty Good Privacy (PGP)

Standard email protocols (SMTP/POP3) transmit in plaintext without authentication. **PGP (Pretty Good Privacy)** is a decentralized cryptographic application providing Email Authentication and Confidentiality.

PGP CRYPTOGRAPHIC PIPELINE (AUTH & CONFIDENTIALITY)

PGP OPERATIONAL MECHANISMS

1. PGP Authentication (Digital Signature):

• Sender A computes hash $H(M)$ of message M.
• Sender encrypts hash $H(M)$ using **Sender's Private Key (PR_A)** $\implies$ Digital Signature.
• Signature is attached to M, compressed (Z), and sent.
• Receiver B decrypts signature using **Sender's Public Key (PU_A)**, computes $H(M)$ locally, and verifies origin & integrity!

2. PGP Confidentiality (Hybrid Encryption):

• Sender A compresses message $M \implies Z(M)$.
• Sender generates a random, one-time symmetric session key K_s.
• Message is encrypted using fast symmetric encryption: $E_{Ks}(Z(M))$.
• Session key K_s is encrypted using **Receiver's Public Key (PU_B)**: $E_{PUB}(K_s)$.
• Receiver B decrypts K_s using **Receiver's Private Key (PR_B)**, then decrypts message using K_s.

3. Combined PGP Services: Applies Authentication first (sign with PR_A), then Confidentiality second (encrypt payload with K_s and K_s with PU_B).

EXAM POINT / COMMON MISTAKE

NPTEL Exam Focus: In PGP Authentication, the hash is encrypted with **Sender's Private Key**. In PGP Confidentiality, the symmetric session key K_s is encrypted with **Receiver's Public Key**! Memorize these key pairs for exam MCQs!

MODULE 6: WEEK 8 REVISION & NPTEL EXAM PREPARATION PAGES

6.1 Quick Week 8 Core Revision Summary

Core Takeaways to Memorize:

• **Steganography:** Hides message *existence* (unlike Cryptography which hides meaning). Cover Medium + Payload + Stego-Key $\implies$ Stego-Medium.

• **LSB Steganography:** Modifies lowest bit of color byte (± 1 intensity change). Requires **Lossless** compression (GIF, BMP). Fails on **Lossy** JPEG compression.

• **LSB Capacity Formula:** $\text{Bytes} = (W \times H \times b) / 8$. For 1500×1200 at 1 bit/pixel $\implies \mathbf{225,000\text{ bytes}}$.

• **Biometrics:** Requires physical presence. *Biological* (Fingerprint minutiae, Retina, Iris, Hand Geometry, DNA) vs. *Behavioral* (Signature, Keystroke, Gait).

• **Biometric Modes:** 1-to-1 Verification ('Are you who you claim to be?') vs. 1-to-N Identification ('Who are you?').

• **Smurf DoS:** ICMP Echo Request to Broadcast Address + Spoofed Victim Source IP $\implies$ Floods victim with ping replies.

• **Ping of Death:** Oversized ICMP packet $> 65,535\text{ bytes}$ causes reassembly buffer crash.

• **SYN Flood:** Spoofed `SYN` packets exhaust TCP half-open connection backlog table. Mitigated by **SYN Cookies**.

• **DDoS Architecture:** Attacker $\rightarrow$ Handlers/Masters $\rightarrow$ Bots/Zombies $\rightarrow$ Botnet.

• **HTTP POST Flood:** Severe processing asymmetry (simple client request forces heavy server execution and SQL queries).

• **DNS Cache Poisoning:** Injecting fake IP mapping into local DNS resolver cache during query window. Mitigated by **DNSSEC**.

• **PGP Email Security:** Authentication (Sign hash with Sender's Private Key PR_A) + Confidentiality (Encrypt payload with session key K_s, encrypt K_s with Receiver's Public Key PU_B).

6.2 Important Definitions & Terminology

Term	Technical Definition	Security / Exam Significance
Steganography	Hiding secret payload data inside innocent cover media.	Conceals communication existence entirely.
Steg-analysis	Science of detecting hidden messages in stego-media.	Counter-measure to steganography.
Minutiae	Specific ridge coordinate points in fingerprints (endings, bifurcations).	Stored as small vector templates (< 1 KB) instead of raw images.
Multimodal Biometrics	Combining 2+ distinct biometric traits for authentication.	Eliminates single-trait errors and physical spoofing.
Smurf Attack	ICMP Echo request to broadcast IP with spoofed victim source address.	Traffic amplification attack; mitigated by blocking broadcast pings.
Half-Open Connection	TCP connection state where `SYN` is received, `SYN-ACK` sent, but no final `ACK` received.	Resource consumed in SYN flood attacks; solved by SYN Cookies.
Botnet	Network pool of compromised devices running automated bot malware.	DDoS power source; controlled via intermediate Handlers.
WAF	Web Application Firewall inspecting Layer 7 HTTP/HTTPS traffic.	Mitigates HTTP GET/POST floods using IP reputation databases.
DNS Cache Poisoning	Injecting fraudulent IP mappings into a DNS resolver cache.	Redirects users to malicious phishing websites.
DNSSEC	IETF suite adding cryptographic digital signatures to DNS records.	Guarantees DNS origin authentication and data integrity.
PGP	Pretty Good Privacy hybrid cryptosystem for email security.	Provides sender authentication and message confidentiality.

6.3 Important Master Concept Comparisons

Comparison Category	Concept A	Concept B	Key Distinguishing Factor
Information Security	**Steganography** Hides message *existence*.	**Cryptography** Hides message *meaning*.	Steganography avoids raising suspicion; Cryptography uses visible locks.
Image Compression	**Lossless (GIF, BMP)** Preserves exact pixel values.	**Lossy (JPEG)** Discards fine pixel detail.	Simple LSB steganography **requires Lossless** compression.
Biometric Traits	**Biological Traits** Fingerprint, Iris, Retina, Face.	**Behavioral Traits** Signature, Keystroke, Gait.	Biological traits are physical body structures; Behavioral traits are learned habits.
Biometric Modes	**1-to-1 Verification** Compares sample to 1 template.	**1-to-N Identification** Compares sample to N templates.	1-to-1 answers 'Are you User A?'; 1-to-N answers 'Who are you in DB?'
DoS Attack Vectors	**Smurf Attack** ICMP Echo + Broadcast IP.	**SYN Flood** TCP 3-way handshake.	Smurf exploits network ping amplification; SYN Flood exploits TCB connection backlog.
HTTP Floods	**GET Flood** Requests file downloads.	**POST Flood** Submits form data.	POST flood creates severe **Processing Asymmetry** (heavy server execution & SQL queries).
DNS Query Methods	**Iterative Resolution** Client manages step queries.	**Recursive Resolution** Local DNS manages step queries.	Recursive resolution places query load on Local DNS server.
PGP Cryptography	**PGP Authentication** Sign hash with PR_A.	**PGP Confidentiality** Encrypt payload with K_s.	Authentication uses Sender's Private Key; Confidentiality uses Receiver's Public Key.

6.4 Formula Sheet & Solved Mathematical Examples

SOLVED MATHEMATICAL EXAMPLE 1: LSB IMAGE CAPACITY

SOLVED EXAMPLE 1 (Image LSB Capacity - Assignment 8 Q10):
Problem: Consider a grayscale image of size 1500×1200, where each pixel is stored using 8 bits. Using LSB steganography (1 bit hidden per pixel), how many bytes of information can be hidden in this image?
Formula: $\text{Capacity (Bytes)} = (W \times H \times b) / 8$
Calculation:
• Total Pixels $W \times H = 1500 \times 1200 = 1,800,000\text{ pixels}$.
• Total Hidden Bits = $1,800,000 \times 1\text{ bit/pixel} = 1,800,000\text{ bits}$.
• Total Hidden Bytes = $1,800,000 / 8 = \mathbf{225,000\text{ bytes}}$.
Final Output: 225,000 bytes (or 225 KB).

SOLVED EXAMPLE 2: BIOMETRIC SEARCH COMPLEXITY

SOLVED EXAMPLE 2 (1:1 vs 1:N Biometric Database Comparisons):
Problem: An enterprise has enrolled 100,000 employees in a biometric database. Compare the number of template matching operations required for: (a) 1-to-1 Verification at the entrance gate, and (b) 1-to-N Identification of an unknown suspect.
Calculation:
• *(a) 1-to-1 Verification:* Employee presents ID card claiming User ID #42,105. System fetches 1 template and performs **1 single comparison**. Search complexity $O(1)$.
• *(b) 1-to-N Identification:* Suspect presents biometric sample without ID. System compares sample against all enrolled templates. In worst case, system performs **100,000 comparisons**! Search complexity $O(N)$.

6.5 NPTEL Exam Practice: Assignment 8 Solved MCQs

Full solutions and explanations for NPTEL Assignment 8 exam questions:

Q1: Which of the following statements best describes steganography?

a. Encrypting information using public and private keys.
b. Embedding information within another cover medium.
c. Tunnelling data using HTTPS and TLS.
d. Compressing data to reduce its transmission size.
e. None of these.

Correct Answer: b

Solution Note: Explanation: Steganography is the practice of hiding the existence of a message by embedding it within another medium such as an image, audio, or video file. Option (a) is encryption; option (d) is compression.

Q2: Which of the following are valid examples of steganography? (Select all that apply)

a. Hiding text data within an image file.
b. Hiding secret data within an audio clip.
c. Encrypting a file so only the recipient can decrypt it.
d. Hiding data within an executable file.
e. Digitally signing a document to prove authorship.

Correct Answer: a, b, d

Solution Note: Explanation: Steganography involves hiding data inside cover media like images, audio clips, or executable headers. Encrypting a file (c) is cryptography; digital signatures (e) relate to authentication/non-repudiation.

Q3: Which of the following is/are examples of behavioural biometrics? (Select all that apply)

a. Fingerprint | b. Signature dynamics | c. Gait | d. Iris pattern | e. Keystroke dynamics | f. Retina pattern | g. Facial structure

Correct Answer: b, c, e

Solution Note: Explanation: Behavioural biometrics relate to patterns in human behavior (signature dynamics, gait, keystroke dynamics). Fingerprint, iris, retina, and facial structure are physiological (biological) traits.

Q4: Which biometric modality is generally considered to offer very high uniqueness and reliability for identification?

a. Voice recognition | b. Facial recognition | c. Iris scan | d. Signature dynamics | e. Gait analysis

Correct Answer: c

Solution Note: Explanation: Iris recognition offers extremely high uniqueness and reliability because the iris pattern contains complex, random structural details that are highly distinctive for every individual.

Q5: What is a Denial-of-Service (DoS) attack?

a. An attack that deletes or modifies files stored on a system.
b. An attack that prevents legitimate users from accessing a service.
c. An attack that specifically targets and destroys stored password databases.
d. None of these.

Correct Answer: b

Solution Note: Explanation: A DoS attack aims to make a network service or system inaccessible to legitimate users by overwhelming its resources.

Q6: How does a Smurf DoS attack typically work?

a. It sends oversized IP packets to crash the target host.
b. It sends forged ICMP Echo requests to a network's broadcast address with the victim's spoofed source IP.
c. It exploits buffer overflow vulnerability in web server software.
d. It uses SQL injections to compromise a backend database.

Correct Answer: b

Solution Note: Explanation: In a Smurf attack, the attacker sends ping requests to a broadcast address with the source IP spoofed to the victim's address. All network hosts respond to the victim, flooding it with replies.

Q7: Which of the following attacks exploits the TCP three-way handshake by leaving connections in a half-open state?

a. Ping of Death attack | b. SYN flooding attack | c. Smurf attack | d. DNS spoofing attack

Correct Answer: b

Solution Note: Explanation: SYN flooding sends numerous SYN requests with spoofed source IPs without sending the final ACK, leaving connections in a half-open state that exhausts server memory.

Q8: What does PGP (Pretty Good Privacy) primarily provide for secure email communication? (Select all that apply)

a. Authentication of the sender | b. Confidentiality of the message content | c. Guaranteed message availability | d. Protection against email spam filtering

Correct Answer: a, b

Solution Note: Explanation: PGP provides authentication (digital signatures using sender's private key) and confidentiality (hybrid encryption using symmetric session keys). It does not guarantee availability or spam protection.

Q9: What is the primary purpose of the Domain Name System (DNS)?

a. To provide end-to-end encryption for email communication.
b. To translate human-readable domain names into IP addresses.
c. To compress and fragment large network messages.
d. To hide secret data inside cover media files.

Correct Answer: b

Solution Note: Explanation: The core function of DNS is resolving human-readable domain names (e.g. `www.google.com`) into numerical IP addresses.

Q10: Consider a grayscale image of size 1500 x 1200, where each pixel is stored using 8 bits. Using LSB steganography (1 bit hidden per pixel), how many bytes of information can be hidden in this image?

a. 180000 | b. 225000 | c. 1800000 | d. 1440000

Correct Answer: b (225000 bytes)

Solution Note: Explanation: Total pixels = $1500 \times 1200 = 1,800,000$. At 1 bit per pixel $\implies 1,800,000\text{ bits}$. In bytes: $1,800,000 / 8 = 225,000\text{ bytes}$.

6.6 Oral Viva Questions & Concise Answers

Q: 1. What is the difference between Steganography and Cryptography?

A: Steganography hides the *existence* of a message; Cryptography hides the *meaning* of an unreadable message.

Q: 2. Why is Lossless compression required for LSB image steganography?

A: Lossless compression (GIF, BMP) preserves exact pixel bit values. Lossy compression (JPEG) discards fine bit detail, destroying the hidden message.

Q: 3. What are Minutiae in fingerprint biometrics?

A: Minutiae are specific ridge coordinate landmarks like ridge endings, bifurcations, cores, and deltas stored as small templates.

Q: 4. Differentiate between 1-to-1 Verification and 1-to-N Identification.

A: 1-to-1 Verification compares a live sample to 1 claimed template ('Are you Alice?'). 1-to-N Identification compares a sample against N database templates ('Who are you?').

Q: 5. How does a Smurf attack amplify ping traffic?

A: It sends an ICMP Echo Request to a network Broadcast Address with the Victim's spoofed source IP, forcing all network hosts to flood the victim with replies.

Q: 6. What causes a Ping of Death crash?

A: An ICMP packet larger than 65,535 bytes is fragmented; upon reassembly, the oversized packet overflows the target OS memory buffer.

Q: 7. How do SYN Cookies defend against TCP SYN Flooding?

A: SYN Cookies eliminate server connection state allocation until the client returns a valid final ACK containing a cryptographic sequence cookie.

Q: 8. Why are HTTP POST floods more destructive than GET floods?

A: POST requests trigger complex server backend code execution and database SQL queries, creating severe processing asymmetry.

Q: 9. How does DNS Cache Poisoning redirect web traffic?

A: An attacker floods a DNS resolver with fake IP mapping responses during a query window, caching a malicious IP for a domain.

Q: 10. In PGP email security, how is message authentication achieved?

A: The sender hashes the message and encrypts the hash with the **Sender's Private Key** to create a digital signature.

6.7 Final Revision Checklist

EXAM READINESS CHECKLIST

[ ] Master Steganography vs Cryptography vs Watermarking definitions.
[ ] Understand LSB insertion mechanics and calculate image capacity ($W \times H \times b / 8$).
[ ] Differentiate Biological (Fingerprint, Iris, Retina, Face) vs Behavioral (Signature, Gait, Keystroke) biometrics.
[ ] Differentiate 1-to-1 Verification vs 1-to-N Identification modes.
[ ] Explain Smurf DoS attack (ICMP + Broadcast + Spoofing) and edge router mitigation.
[ ] Explain Ping of Death (>65,535 bytes) and SYN Flooding (TCP half-open connections).
[ ] Understand SYN Cookies defense mechanism.
[ ] Describe DDoS Architecture (Attacker $\rightarrow$ Handlers $\rightarrow$ Bots $\rightarrow$ Botnet).
[ ] Explain HTTP POST flood processing asymmetry and WAF/CAPTCHA defenses.
[ ] Understand DNS Cache Poisoning and DNSSEC digital signatures.
[ ] Master PGP Email Authentication (Sign with PR_A) and Confidentiality (Hybrid K_s + PU_B).